

CSC 653

Network Security

Final Report

Harper (Eunhui) Cho

Student ID: 925096897

Contents

1. Introduction
 - A. Problem Motivation
 - B. ML vs Rule-based
2. Methodology
 - A. Pipeline
 - B. Dataset Overview
 - C. Label Re-grouping
3. Attack Feature Analysis
 - A. Analysis Strategy
 - B. Category vs Benign
 - C. Category vs Category
 - D. Threshold Selection
4. Detection Rule Design
5. Evaluation
 - A. Train Performance
 - B. Test Validation
6. Discussion - Attack-wise Analysis & Limitations
7. Conclusion

1. Introduction

A. Problem Motivation

Network Intrusion Detection Systems (NIDS) are essential for identifying malicious activities in network traffic. While machine learning approaches have achieved high detection accuracy, they often function as "black boxes," making it difficult to understand why a specific traffic flow was classified as an attack.

In network forensics, explainability is critical. Security analysts need to understand not just that an attack occurred, but why and how it was detected. This understanding enables proper incident response, rule refinement, and knowledge transfer.

This project focuses on developing explainable rule-based detection derived from data-driven traffic analysis using the CIC-IDS2018 dataset.

B. ML vs Rule-based

Machine learning-based IDSs are effective when large amounts of labeled data are available and when detection performance is the primary objective.

However, these models typically require complex training procedures and produce decision boundaries that are difficult to interpret.

In contrast, rule-based IDSs operate using explicit conditions defined on traffic features, such as packet rates or flow durations.

Each detection decision can be directly explained by specific feature thresholds, making rule-based systems highly suitable for forensic investigation and operational environments where explainability is required.

Nevertheless, rule-based detection is not universally effective for all attack types.

Its performance strongly depends on whether attack behaviors are clearly separable from benign traffic at the flow level.

Motivated by this trade-off, this study investigates where rule-based intrusion detection works well and where it fails, under strict false positive rate constraints.

By systematically analyzing traffic features, designing threshold-based rules, and validating them on unseen test data, this work aims to clarify the practical strengths and structural limitations of flow-level rule-based IDS.

2. Methodology

A. Pipeline

This project follows a four-stage pipeline for rule-based network intrusion detection:

Stage 1: Data Preparation

The CSE-CIC-IDS2018 dataset was preprocessed and labels were regrouped into four attack categories. The data was split into training (80%) and test (20%) sets. Preprocessing included removing duplicates and handling infinite values.

Stage 2: Feature Analysis (Train)

Exploratory data analysis was conducted on the training set to identify distinguishing features for each attack category. This included Category vs Benign comparison using effect size (Cohen's d) and mean ratio, followed by Category vs Category comparison to find features that separate different attack types. Based on these analyses, detection rules were defined.

Stage 3: Rule Design & Threshold Optimization (Train)

The derived rules were applied to the test set for rule-based detection. Performance was evaluated using Recall, FPR, Precision, and F1-score.

Stage 4: Test Validation & Output

The system outputs the detected attack category along with an explanation of which rule conditions were triggered, enabling forensic analysis.

B. Dataset Overview

This study uses the CIC-IDS2018 dataset, a widely used benchmark dataset for intrusion detection research.

The dataset contains labeled network flow records extracted from realistic network traffic, including both benign activity and multiple attack scenarios.

Each record represents a bidirectional network flow and includes flow-level statistical features such as packet counts, byte counts, inter-arrival times, and header-related metrics.

No payload-level or content-based features are used in this study, in order to focus exclusively on flow-level behavior.

The dataset is divided into training and test subsets following the original dataset split.

All rule design and threshold selection processes are conducted using only the training data, and the test data is used solely for final performance validation.

C. Label Re-grouping

The original CIC-IDS2018 dataset contains multiple attack labels that differ in both attack semantics and traffic behavior.

To simplify the analysis and focus on behavioral patterns observable at the flow level, the original attack labels are re-grouped into four broader categories.

Although some attacks share similar names, they operate at different layers of the network stack and exhibit different traffic characteristics.

For example, FTP brute force attacks target a network service and generate clear flow-level patterns such as frequent connection attempts and high packet rates.

As a result, FTP brute force is treated as a separate category suitable for flow-based rule design.

In contrast, web brute force, XSS, and SQL injection operate at the application layer.

Their attack logic primarily resides in request payloads or application-level semantics, which are not directly observable through flow-level statistics.

Additionally, some of these attacks have relatively small sample sizes.

For these reasons, web brute force, XSS, and SQL injection are grouped into a single Web Attack category to ensure stable and meaningful analysis.

```
Label distribution:
Benign                : 11,307 samples
DoS attacks-GoldenEye : 2,363 samples
DDoS attacks-LOIC-HTTP : 2,349 samples
FTP-BruteForce        : 2,324 samples
DoS attacks-SlowHTTPTest : 2,321 samples
Bot                   : 1,327 samples
DDoS attack-LOIC-UDP  : 1,112 samples
Brute Force -Web      : 489 samples
Brute Force -XSS      : 184 samples
SQL Injection         : 70 samples
```

```
[Benign] - 11307 samples
- Benign: 11307 samples

[DoS/DDoS] - 8145 samples
- DoS attacks-GoldenEye: 2363 samples
- DDoS attacks-LOIC-HTTP: 2349 samples
- DoS attacks-SlowHTTPTest: 2321 samples
- DDoS attack-LOIC-UDP: 1112 samples

[Brute Force] - 2324 samples
- FTP-BruteForce: 2324 samples

[Botnet] - 1327 samples
- Bot: 1327 samples

[Web Attack] - 743 samples
- Brute Force -Web: 489 samples
- Brute Force -XSS: 184 samples
- SQL Injection: 70 samples
```

3. Attack Feature Analysis

A. Analysis Strategy

The feature analysis followed a systematic four-step approach to identify discriminative features and derive detection thresholds:

Step 1: Re-grouping

Assign regrouped attack categories and verify label distribution to ensure balanced representation for analysis.

Step 2: Category vs Benign

Analyze feature distributions for each attack category compared to benign traffic. This step identifies features that distinguish attacks from normal traffic using statistical measures.

Step 3: Category vs Category

Compare feature patterns across different attack categories to identify features that can separate one attack type from another. This is essential for hierarchical rule design.

Step 4: Threshold Selection

Derive optimal threshold values for rule-based detection using FPR-constrained optimization.

B. Category vs Benign

The category-versus-benign analysis reveals that the separability between attack traffic and benign traffic varies significantly across attack types.

Effect Size (Cohen's d): Cohen's d measures how well the distributions of attack and benign traffic are separated, independent of scale. Values above 0.8 indicate large effect sizes, meaning the feature strongly distinguishes between the two groups.

Mean Ratio (Attack Mean / Benign Mean): The ratio reflects the magnitude of difference in actual feature values, which is useful for defining practical thresholds.

Key Findings: The analysis revealed that top-ranked features were highly similar across attack categories. Features like Init Fwd Win Byts, Flow Duration, and Fwd Seg Size Min appeared in the top 5 for multiple attack types. This indicates that while attacks differ from benign traffic, different attack types share overlapping traffic patterns at the flow level.

B.1. Brute Force

Brute Force attacks show strong separation from benign traffic in multiple flow-level features, particularly those related to packet rate and window size. Features such as packets per second and initial forward window bytes exhibit large effect sizes and clear distribution gaps, indicating that Brute Force behavior is highly distinguishable at the flow level. This strong separability explains why Brute Force attacks can be detected with high recall even under strict false positive rate constraints.

B.2. DoS/DDoS

DoS and DDoS attacks exhibit moderate but consistent separation from benign traffic. Several features related to traffic intensity and timing show noticeable distribution shifts; however, partial overlap with benign high-throughput traffic remains. As a result, while DoS/DDoS attacks are detectable using flow-level rules, increasing recall often leads to increased false positives, indicating an inherent trade-off.

B.3. Botnet

In contrast, Botnet traffic shows substantial overlap with benign traffic across the analyzed flow-level features. Even features with relatively large effect sizes fail to provide clear separation under strict false positive constraints. This observation suggests that Botnet behavior is not well captured by simple flow-level statistics and likely requires temporal, behavioral, or learning-based representations.

B.4. Web Attack

Web Attacks demonstrate limited separability from benign traffic at the flow level. Although some features show moderate differences, the overall separation remains weak and inconsistent. This indicates that application-layer attacks such as web brute force, XSS, and SQL injection are difficult to distinguish using flow-level statistics alone, as their defining characteristics primarily reside in payload content and request semantics.

C. Category vs Category

After analyzing each category versus Benign, the top features were almost identical across attack types. This means different attack types shared highly overlapping traffic patterns when compared to benign traffic. Therefore, inter-category comparison was performed to find features that distinguish one attack type from another.

For DoS/DDoS versus Brute Force, Bwd Pkts/s (backward packets per second) was used as the distinguishing feature. This feature represents the server to client response rate. Brute Force shows extremely high backward packet rates due to repeated authentication responses, while DoS does not.

For DoS/DDoS versus Botnet, Init Fwd Win Byts (initial TCP window size in forward direction) was used. This feature indicates transmission intent. DoS sets high initial window sizes for massive data transmission, while Botnet keeps it low for stealthy communication.

For Brute Force versus Botnet, both Bwd Pkts/s and Init Fwd Win Byts combined clearly separate these categories.

These comparisons determined the hierarchical rule order: Brute Force is checked first because Bwd Pkts/s clearly separates it from all other attack types, then Botnet and DoS/DDoS are distinguished by Init Fwd Win Byts.

D. Threshold Selection

A threshold is a decision boundary that determines whether a feature value indicates an attack or benign traffic. For example, if the backward packets per second is higher than a certain number, we classify the traffic as a Brute Force attack.

Thresholds were chosen using two criteria. First, we limit the False Positive Rate (FPR), called alpha (α). FPR is the rate at which normal traffic is wrongly detected as an attack. This means we decide in advance how much normal traffic we are willing to misclassify as attacks. Second, among the thresholds that meet this limit, we choose the one with the highest Recall.

To find threshold candidates, we used percentile values from the attack and benign data, such as the 90th, 95th, and 99th percentiles. All candidate thresholds were tested using AND rules, and the final threshold was selected based on the best Recall under the FPR limit.

4. Detection Rule Flow

In the previous section, features were selected based on effect size and attack-to-benign ratios, focusing on features that show clear statistical separation. This section explains how those selected features are organized into a rule-based detection flow.

The overall idea is to process traffic sequentially, starting from attacks with the strongest and most distinctive patterns. When traffic is input, each rule is checked in order. If a rule matches, the traffic is classified as that attack type. If no rule matches, the traffic is classified as Benign.

3. Step 1: Brute Force

Brute Force is checked first. Brute Force shows very strong separation in features such as backward

packet rate and initial forward window bytes, so it is placed at the first stage using a strict AND rule.

Rule: IF Bwd Pkts/s $\geq$ threshold_very_high AND Init Fwd Win Byts $\geq$ threshold_high THEN $\rightarrow$ "Brute Force"

Step 2: Botnet

Next, Botnet is evaluated. This stage focuses on flow-level timing and packet length characteristics and is positioned after Brute Force to avoid interference with more clearly separable attacks.

Rule: IF Flow Duration $\leq$ threshold_very_low AND Pkt Len Mean $\leq$ threshold_very_low THEN $\rightarrow$ "Botnet"

Step 3: DoS/DDoS

Then, DoS/DDoS is examined using control-flag behavior and window size features. This stage captures high-volume or aggressive traffic patterns that are less specific than Brute Force but still structurally different from normal traffic.

Rule: IF PSH Flag Cnt $\geq$ threshold_low AND Init Fwd Win Byts $\geq$ threshold_mid THEN $\rightarrow$ "DoS/DDoS"

Step 4: Web Attack

Finally, Web Attacks are evaluated. Because web-based attacks tend to be more subtle and diverse, a k-of-n rule is used, where multiple partial conditions can collectively indicate suspicious behavior.

Rule: IF 2 or more conditions satisfied among Subflow Fwd Byts $\geq$ threshold_high, Fwd Header Len $\geq$ threshold_mid, and Fwd Pkt Len Std $\geq$ threshold_mid THEN $\rightarrow$ "Web Attack (Suspicious)"

Step 5: Benign

If none of the above rules match, the traffic is classified as Benign.

All thresholds in this flow were determined on the training data by maximizing Recall under predefined FPR constraints, and the finalized rules are applied sequentially to incoming traffic.

5. Evaluation

A. Train Performance

The detection rules were first evaluated on the training data. Two optimization stages were applied: Step 3 performed threshold search with AND rules and Recall-oriented optimization, while Step 4

applied explicit FPR constraints (α) and analyzed trade-offs to finalize rules.

Brute Force achieved the highest performance with 96.60% Recall and 0.88% FPR, resulting in an F1-score of 0.9619. The strict AND rule with Bwd Pkts/s and Init Fwd Win Byts successfully captured the distinctive pattern of repeated authentication attempts.

Botnet showed 0% Recall with 4.40% FPR, resulting in an F1-score of 0. This indicates a structural limitation of the rule-based approach for this attack type, which will be discussed in the Discussion section.

DoS/DDoS was evaluated under two FPR constraints. With $\alpha=0.05$, the rule achieved 56.50% Recall and 4.38% FPR (F1=0.6951). With a relaxed constraint of $\alpha=0.10$, performance slightly improved to 57.51% Recall and 5.62% FPR (F1=0.6958). The relaxed constraint was selected for the final rule.

Web Attack was also evaluated with two rule types. The strict AND rule achieved 26.38% Recall and 0.96% FPR (F1=0.3740). The k=2-of-3 rule achieved similar Recall of 26.11% with lower FPR of 0.82% (F1=0.3767). The k=2-of-3 rule was selected for better precision.

Category	Step	Recall	FPR	F1 비교
Brute Force	Step3	0.9660	0.0088	0.9619
Botnet	Step3	0.0000	0.0440	0.0000
DoS/DDoS	Step3	0.5650	0.0438	0.6951 $\alpha=0.05$
	Step4B	0.5751	0.0562	0.6958 $\alpha=0.10 \uparrow$
Web Attack	Step3	0.2638	0.0096	0.3740 AND rule
	Step4A	0.2611	0.0082	0.3767 k=2-of-3 $\downarrow$

B. Test Validation

The finalized rules were applied to the test data to verify generalization performance. The key question was whether the rules derived from training data would maintain similar performance on unseen data.

Brute Force maintained excellent performance with 95.87% Recall and 0.57% FPR on test data, compared to 96.60% Recall and 0.88% FPR on training data. The small difference (less than 1 percentage point) confirms stable generalization.

Botnet showed consistent behavior with 0% Recall on both training and test data. The FPR was 4.07% on test data compared to 4.40% on training data.

DoS/DDoS achieved 57.54% Recall and 5.34% FPR on test data, nearly identical to the training performance of 57.51% Recall and 5.62% FPR.

Web Attack showed 25.95% Recall and 0.88% FPR on test data, compared to 26.11% Recall and

0.82% FPR on training data.

The differences between training and test performance are very small across all attack types. This indicates no overfitting, meaning the rules and thresholds are not dataset-specific. The final rules show stable and reproducible behavior under FPR constraints.

Category	Train Recall	Test Recall	Train FPR	Test FPR
Brute Force	0.9660	0.9587	0.0088	0.0057
Botnet	0.0000	0.0000	0.0440	0.0407
DoS/DDoS	0.5751	0.5754	0.0562	0.0534
Web Attack	0.2611	0.2595	0.0082	0.0088

6. Discussion - Attack-wise Analysis & Limitations

The evaluation results show varying detection performance across attack categories. This section analyzes the success and failure cases to understand the strengths and limitations of rule-based detection.

Success Case: Brute Force

Brute Force detection achieved the best performance with 96% Recall, 0.6% FPR, and F1-score of 0.97. This success is due to the highly distinctive traffic pattern of Brute Force attacks. Repeated authentication attempts generate extremely high backward packet rates as the server responds to each failed login. This pattern is clearly separable from both benign traffic and other attack types using simple threshold rules. The confusion matrix shows 557 true positives with only 16 false positives and 24 false negatives, demonstrating that rule-based detection can be highly effective when attack behavior creates clear statistical separation.

Structural Limitation: Botnet

Botnet detection completely failed with 0% Recall, meaning the rule could not catch any of the actual Botnet attacks. The confusion matrix shows 0 true positives out of 332 actual Botnet samples, while generating 115 false positives. This failure represents a structural limitation of the rule-based approach. Botnet traffic is designed to mimic normal traffic patterns to avoid detection. The stealthy nature of command-and-control communication means there are no simple threshold-based features that can reliably separate Botnet from benign traffic without also misclassifying a large portion of normal traffic. This demonstrates that rule-based methods have inherent limitations for detecting attacks that deliberately blend with normal behavior.

Functional Saturation: DoS/DDoS and Web Attack

DoS/DDoS achieved moderate performance with 58% Recall and 5.3% FPR ($F1=0.70$), while Web Attack showed lower performance with 26% Recall and 0.9% FPR ($F1=0.37$). These results indicate functional saturation, where the rule-based approach reaches its performance ceiling. For DoS/DDoS, the confusion matrix shows 1,172 true positives but 865 false negatives, meaning nearly half of the attacks were missed. The attack patterns overlap significantly with both benign traffic and other attack types, making it difficult to improve Recall without substantially increasing FPR. For Web Attack, the application-layer nature of these attacks means that flow-level features capture only partial information. Many web attacks appear similar to normal HTTP traffic at the flow level, requiring payload inspection for accurate detection.

Limitations

The rule-based approach works well when attacks create distinctive, measurable patterns in flow-level features. However, it struggles with attacks that mimic normal traffic (Botnet), share patterns with other attack types (DoS/DDoS), or operate at the application layer where flow features provide limited visibility (Web Attack). These limitations suggest that hybrid approaches combining rule-based detection with machine learning or deep packet inspection may be necessary for comprehensive network security.

7. Conclusion

This project developed an explainable rule-based network intrusion detection system using the CIC-IDS2018 dataset. The primary goal was to create detection rules that are transparent and interpretable, enabling security analysts to understand not just that an attack was detected, but why and how.

The methodology followed a systematic pipeline: preprocessing and label regrouping, feature analysis using effect size and mean ratio, inter-category comparison to identify distinguishing features, FPR-constrained threshold optimization, and hierarchical rule design. This data-driven approach ensures that detection rules are grounded in statistical evidence rather than arbitrary expert judgment.

The evaluation demonstrated varying levels of success across attack categories. Brute Force detection achieved excellent performance ($F1=0.97$), proving that rule-based methods can be highly effective when attack patterns are distinctive. DoS/DDoS detection showed moderate success ($F1=0.70$), capturing the majority of high-volume attacks while maintaining acceptable false positive rates. Web Attack detection achieved limited success ($F1=0.37$) due to the application-layer nature of these attacks. Botnet detection failed completely ($F1=0$), revealing the fundamental limitation of threshold-based rules against stealthy attacks designed to mimic normal traffic.

The consistent performance between training and test data confirms that the derived rules generalize well and are not overfitted to the training set. All FPR constraints were satisfied on both datasets, demonstrating the reliability of the FPR-constrained optimization approach.

The key contribution of this project is demonstrating both the potential and the boundaries of rule-based detection. For attacks with clear traffic signatures, simple threshold rules provide transparent, explainable, and effective detection. For sophisticated attacks that blend with normal traffic, rule-based methods reach their structural limits, motivating the need for complementary approaches.

Future work could explore several directions: integrating machine learning models for attack categories where rule-based detection fails, incorporating payload analysis for application-layer attacks, developing hybrid systems that combine the explainability of rules with the pattern recognition capability of machine learning, and extending the approach to real-time detection scenarios with streaming traffic data.